

DARK READING

VULNERABILITIES & THREATS

APPLICATION SECURITY

CYBERSECURITY OPERATIONS

THREAT INTELLIGENCE



Cybersecurity In-Depth: Feature articles on security strategy, latest trends, and people to know.

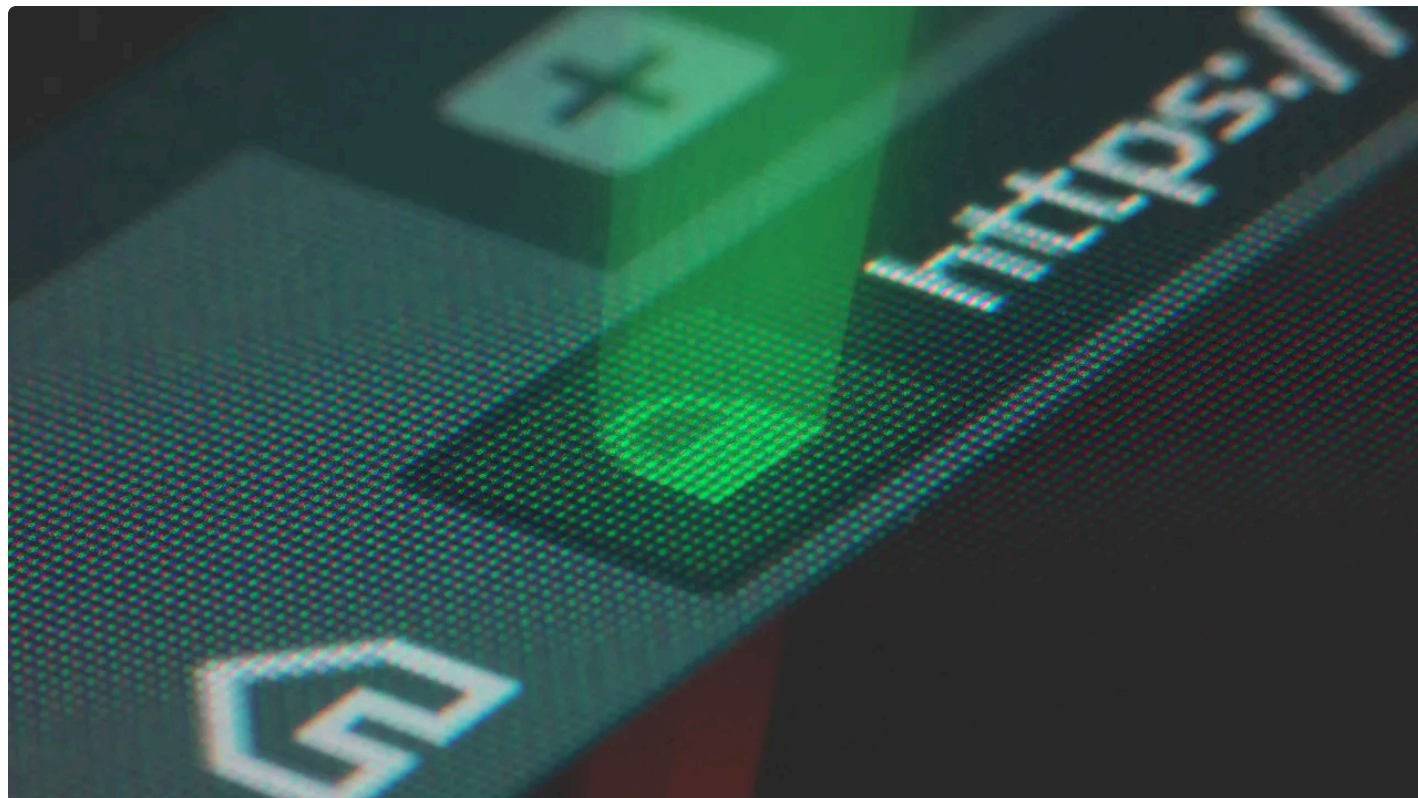
Browser Exploits Wane as Users Become the Attack Surface

For browsers, exploitation is out — and getting users to compromise their own systems is in. Improved browser security has forced attackers to adapt their tactics, and they've accepted the challenge.

**Robert Lemos**, Contributing Writer

July 10, 2025

6 Min Read



SOURCE: ROBERT AVGUSTIN VIA SHUTTERSTOCK

Browser exploits continue to haunt enterprise security.

In May, Microsoft [patched a browser vulnerability](#) that could allow attackers to force Edge users into Internet Explorer compatibility mode, reducing security protections. A year ago, Google [patched three vulnerabilities](#) in its Chrome browser — two that could lead to a sandbox escape and one that could allow code execution.

Despite the continued trickle of browser vulnerabilities, however, attacking browsers directly is on the decline, experts say. While browser vulnerabilities have accounted for about 2% of all reported flaws since 2017, according to the National Vulnerability Database, attacks have grown more difficult. Nearly all browser exploitations require an exploit chain — a series of attacks against a collection of vulnerabilities — rather than a single exploit that compromises the entire browser.

Overall, browser attacks are shifting away from direct exploitation, says Ray Canzanese, director of the threat labs at cloud security firm Netskope.

Related: Beauty in Destruction: Exploring Malware's Impact Through Art

"We are so far beyond the golden age of the exploit kit. Browsers have improved so much," he says. "They're more hardened. The sandboxing is better. The patching is better. Adobe Flash Player is no longer the thing that [can be] exploited by a lot of those exploit kits. So in general, no, it's not exploits."

Instead, attackers are using browsers as the initial access point for an attack chain that focuses on the end user. In 2024, 70% of attacks used a download through a browser to gain a foothold on a user's system, up from 58% in 2023, according to [a January 2025 analysis](#) of data released by cybersecurity firm eSentire's Threat Response Unit. Attacks that combine social engineering and browser-based vectors — [such as ClickFix](#) — are on the rise.

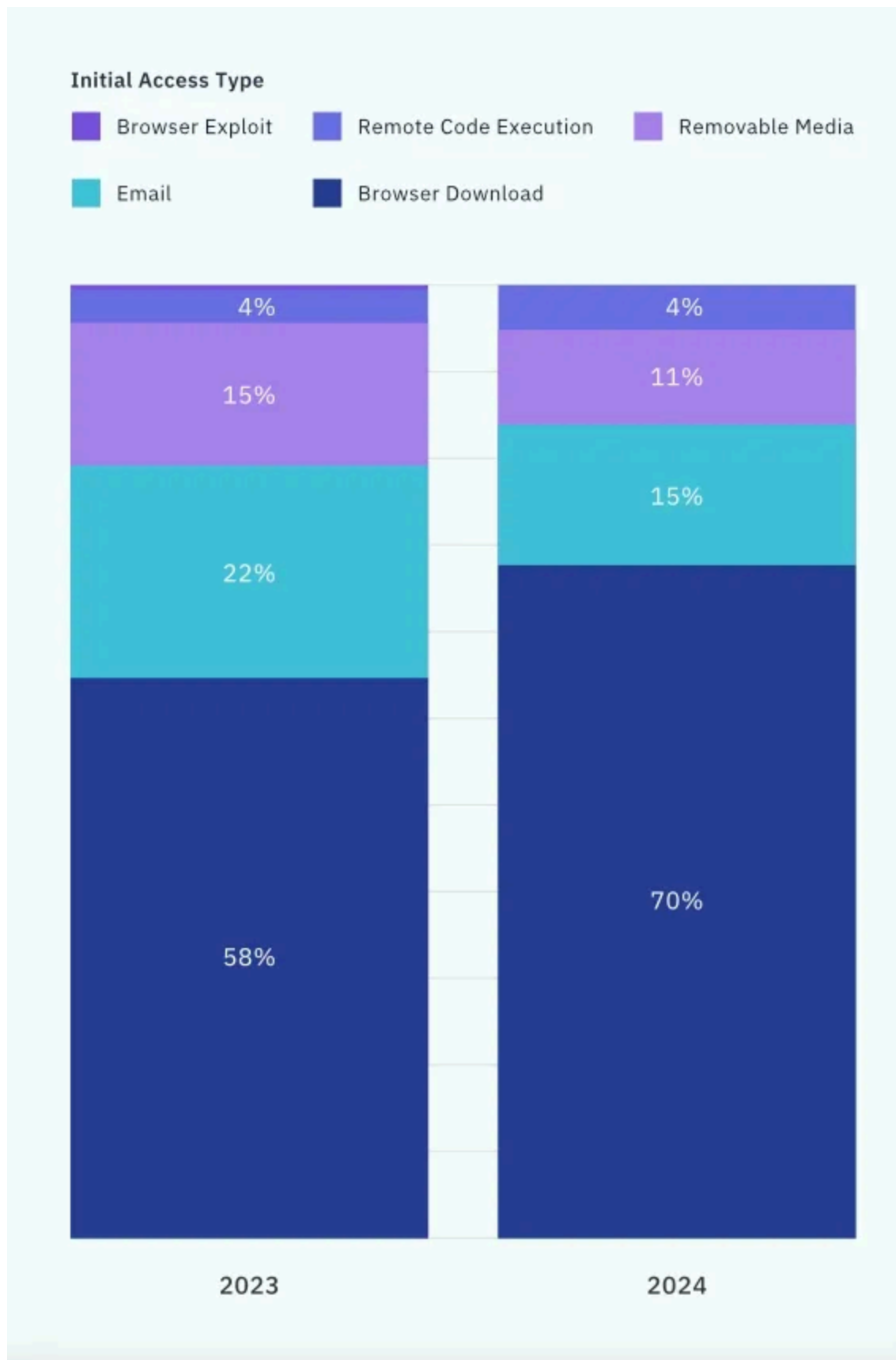
Many classic attacks, such as phishing and malvertising, continue to be threats — especially as AI chatbots make the cost of creating lures much lower — but attackers are shifting to using legitimate browser functionality in ways not intended, according to experts. Browser extensions, in particular, are a significant weak spot because if attackers can get an employee to run a compromised extension, fool an extension developer into allowing modifications, or just buy up a popular extension's project, they have a way to bypass browser security.

Subverting Browsers for Offense

The continued focus on browsers is unsurprising. When conducting browser-based attacks, attackers prioritize stealing credentials to gain access to cloud services or move laterally, deeper into the network. Stealing critical data and a variety of tokens or credentials are the top goals, while the eventual payload may be ransomware or another kind of malware, with the aim of disrupting operations and extracting ransoms, says Neko Papez, senior manager for cybersecurity strategy at Menlo Security.

Related: Pwn2Own Underscores Secure Development Concerns

"Attackers target browsers because they're the gateway to nearly everything employees do online," he says. "Browsers are inherently trusted by users, making them a prime target for attackers to exploit that trust and gain a foothold in the enterprise."



While exploitation remains at 4%, the share of attacks that rely on the browser has surged.
Source: eSentire

The [attack on cybersecurity firm Cyberhaven](#) did exactly that. A fake notification from Google targeted Cyberhaven's developers, convincing one employee to grant access to what seemed to be a legitimate application. The attack exploited the Google Chrome Store's reliance on the OAuth framework to upload malicious modifications to trusted extensions.

Other more advanced attacks are likely on the way as well. Browser security firm SquareX has engineered ways, dubbed "[last-mile reassembly](#)" attacks, to bypass secure Web gateways. The company has also found ways to use the browser to encrypt downloads and other files, dubbed "browser-native ransomware," says Vivek Ramachandran, founder and CEO of SquareX.

Related: 'Claudy Day' Trio of Flaws Exposes Claude Users to Data Theft

It's an attack that "lives and dies in the browser," he says. "It does not require any local files or processes, allowing it to completely bypass existing anti-ransomware and EDR [endpoint detection and response] solutions."

Targeting Specific Worker Roles

While the high-volume browser attacks continue to be focused on consumers, business attacks that target workers or specific organizations are low-volume by nature but critical to stop, says Netskope's Canzanese. Emails that use business-focused lures or malvertising and SEO poisoning that focus on business-oriented information and search terms are increasingly common, he says.

"With these targeted search terms in SEO poisoning, you can get really specific, so we've seen some search terms for things that were clearly not consumer topics, which definitely means they were after the business users," he says. "We've seen manuals for specific, very expensive hardware that no consumer would be using as bait. So it's a blend in the same way that email [attacks] are a blend."

In addition, attackers are focused on specific roles: executives, finance groups, and developers, says SquareX's Ramachandran.

"Many of these attacks target all employees; however, we are indeed seeing some attacks that are attacking privileged users who have access to more company resources, [such as] security [and] IT teams, executives, government officials, and in the case of the Cyberhaven attack, developers in technology companies who have full access to the company's code base," he says, adding that "compromising just one employee now allows access to not just their data but also to any other company resources shared with them."

The increase in browser attacks is also being driven by another factor: the increase in remote work, where employees and third parties often work from unsecured home networks and personal devices, says Menlo Security's Papez.

"This shift outside the traditional corporate perimeter gives attackers more opportunities to exploit browser vulnerabilities and user behavior, increasing the risk of phishing, malware, and data breaches," he says.

Beyond Cloud Defenses

Cloud-based approaches, like secure Web gateways (SWG) and cloud access-security brokers (CASBs) can filter known threats, risky domains, and suspicious code, but they can miss sophisticated browser-based attacks, Papez says. Client-side cybersecurity solutions, such as EDR, can help detect suspicious activity, but only after the attackers have gained some access inside the network.

On the other hand, the most strict defense — [remote browser isolation \(RBI\)](#) — comes with user-experience and scalability challenges, he says.

"Enterprises need solutions designed from the ground up for security, with capabilities embedded directly in the browser to protect users, especially those working remotely," he says.

Enterprise browsers have become a popular solution, but they can have some of the same scalability problems as RBI. Browser-extension-based solutions attempt to add security and telemetry while removing the necessity of a custom browser. In both cases, the organization gains access to information about browser usage and the ability to instantiate security controls, Ramachandran says.

"Extension-based solutions are gaining popularity as they are compatible with all browsers and devices, providing the same browser security functionalities as enterprise browsers without the deployment overhead," he says.

Companies should continue to track attackers' tactics, which continue to adapt. Canzanese sees attackers focused on illicit authorization going after OAuth workflows and on reverse proxies that capture multifactor authentication tokens, while focused less on simple fake login sites. The shift toward ClickFix and other attacks that switch browsers or convince the user to complete the attack chain require good visibility to stop.

"You harden one thing, the attacker just goes and finds the next weakest link," Canzanese says. "If your employees are on unmanaged devices and the only control you have is an enterprise browser, getting the victim to leave the browser would be very effective because you would then be in an environment with far less security controls."

Read more about:

CISO Corner

About the Author



Robert Lemos
Contributing Writer

Veteran technology journalist of more than 20 years. Former research engineer. Written for more than two dozen publications, including CNET News.com, Dark Reading, MIT's Technology Review, Popular Science, and Wired News. Five awards for journalism, including Best Deadline Journalism (Online)...

You May Also Like